

WHEN AI ATTACKS

AI THREAT ASSESSMENT WORKBOOK

Digital Content #2 — AI Supply Chain Attacks: When Your Trusted Tool Becomes the Weapon

Purpose: Use this workbook to assess whether your organization has the controls to detect, prevent, and respond to an AI supply chain attack. If a model integrity incident is active or suspected, go directly to Section 03 — Root Cause.

01 Exposure Check

Answer Yes / No / Unknown for your environment. Every Unknown is a gap. Three or more Unknowns = this is your next tabletop agenda.

Question	Yes	No	Unknown / Gap	Notes
Do you have an inventory of every AI system in production, including the name of the vendor who trained the underlying model?	☐	☐	☐	
For AI systems making consequential decisions, was behavioral integrity testing conducted before deployment?	☐	☐	☐	
Have you required model cards (training data disclosure) from your AI vendors?	☐	☐	☐	
Does your third-party risk process include AI-specific controls beyond infrastructure security?	☐	☐	☐	
Do your AI vendor contracts require notification of model updates that affect behavior?	☐	☐	☐	
Do you log AI model outputs at the decision level — not just aggregate accuracy metrics?	☐	☐	☐	
Is there an independent ground truth validation layer for AI systems making high-value decisions?	☐	☐	☐	
Have you mapped every downstream agent that consumes each AI model's outputs — directly or transitively?	☐	☐	☐	
If a model in production were replaced today, could you identify and audit every decision downstream agents made during the exposure window?	☐	☐	☐	

02 Accountability — Who Owns What

Function	Owner (Name / Role)	Last Reviewed	Gap
AI system inventory and model provenance tracking			☐
Behavioral integrity testing and model validation			☐
AI vendor third-party risk assessment			☐
AI agent registry and downstream pipeline mapping			☐
Model output logging and forensic preservation			☐
Board reporting on AI supply chain risk posture			☐

03 Root Cause — If an Incident Is Active or Suspected

Work through these questions with your IR team. Capture specifics — not "TBD."

	Question	What to Capture
01	What AI system was involved, and what model version was deployed at the time of the suspected incident?	Name the platform, vendor, and model version. Identify the deployment date and last model update.
02	What data did the model process during the suspected period — and what decisions did it influence?	Pull decision logs. If logs do not exist at the output level, document that gap as finding #1.
03	Which downstream agents consumed this model's outputs during the suspected exposure window — and what persistent records did they create or modify?	★ Multi-Agent: Map the full pipeline. Identify every agent in the chain and every record it updated. This defines your blast radius and remediation scope.
04	Can you establish a behavioral baseline comparison — what should the model have produced vs. what it produced?	If no baseline exists, document that gap. Engage the vendor for model card and training data disclosure.

04 Five Questions to Bring to Your Next Executive Meeting

	Question	Your Answer / Status
01	For every AI system in production, can you identify who trained the underlying model and on what data?	
02	What is your process for evaluating model behavioral integrity — not just vendor security posture?	
03	If an AI system in production were producing subtly manipulated outputs today, what control would detect it?	

	Question	Your Answer / Status
04	Do your AI vendor contracts require disclosure of model updates, training data provenance, and behavioral change notifications?	
05	Does your board understand that a compromised AI model can cause material harm without triggering any traditional security alert?	

05 Directives — Assign an Owner and a Date

	Audience	Directive	Owner	Done By
01	CISO	Conduct a full AI model audit. Pull all third-party API connections for the last 90 days. Flag every AI application not provisioned by IT.		
02	CISO	Require model cards from every AI vendor for systems making consequential decisions. Make training data provenance disclosure a contractual requirement.		
03	CISO	Implement behavioral baseline testing before any AI deployment. Scenario-specific test sets, not just aggregate accuracy. Document the baseline.		
04	CISO	Add AI-specific controls to your TPRM process: training data provenance, adversarial testing, model update notification, and behavioral change disclosure.		
05	CISO	Map your multi-agent pipelines. For each AI model, identify every downstream agent that consumes its outputs and document the blast radius.		
06	IR	Build an AI supply chain incident classification in your playbook. Define the evidence set: model output logs, pipeline map, vendor model card, behavioral comparison.		
07	IR	Establish model output logging for every AI system making consequential decisions. Aggregate metrics are not enough — you need decision-level outputs.		
08	IR	Define independent ground truth validation for highest-risk AI decisions. You cannot detect manipulation you have never defined normal behavior for.		
09	IR	Add model update events to your change management process. Every model update triggers a behavioral regression test before production deployment.		
10	IR	★ Multi-Agent: Run a multi-agent containment tabletop — if the model is replaced, can you identify and audit every decision downstream agents made during the compromise window?		

Assessment prepared by Matsui LLC · matsuihq.ai